Jayhackers

University of Kansas

Team 15

White Team Documentation

Contents

General Security Policy 3
Network Diagram 4
Servers 4
Active Directory 5
Ticketing Machine 6
Management Backend 7
Admin User Interface 8
Public Website 10

General Security Policy

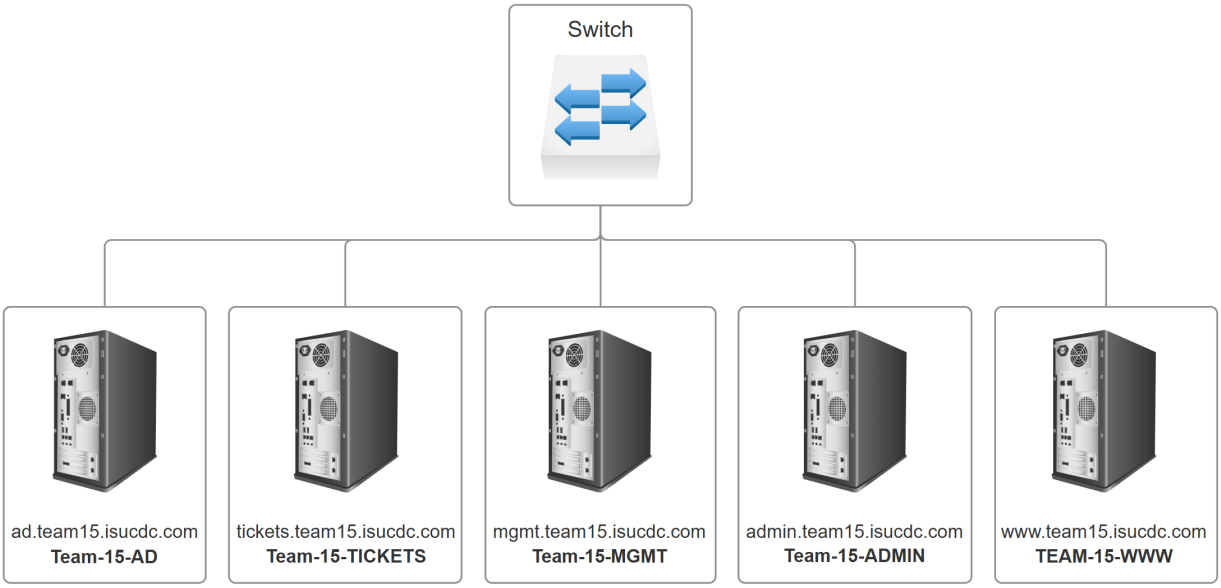
In order to secure the network, we decided to implement some broad security policies that should prove beneficial to the security of all machines.

1. Software Firewalls:
   The first general policy was raising software firewalls on each machine to limit external access. While this solution lacks scalability due to requiring different configurations on each device, it provides major security benefits and makes our network more resistant to internal attacks if one of the servers does get breached.

2. Group User Management:
   The second general policy we implemented was to minimize the amount locally managed users on each server. Because we have an Active Directory in our infrastructure, this is relatively easy to accomplish.

3. Password Rotation:
   The third general policy was to rotate all administrative passwords before launching the website, as we found evidence that the network had been previously tampered with, showing that the credentials could be compromised. Because of the tampering we discovered, we have determined it to be necessary to complete an audit of the entire network. This process will involve both internal and external scans of the network and taking penetration testing approaches to try and identify where any vulnerabilities may exist within the network.

Network Diagram



Servers

The servers within our network have been restated here to clarify what ports are open and what services are being run. We are not using NAT in our infrastructure. All machines have software firewalls configured to limit access to only the listed ports.

Server Name	DNS	IP	Open Ports	Services
AD	ad.team15.isucdc.com	159.75.35.10	389, 636, 3389	LDAP, LDAPS, RDP
TICKETS	tickets.team15.isucdc.com	159.75.35.20	3389, 5000	RDP, HTTP
MGMT	mgmt.team15.isucdc.com	159.75.35.30	22, 5000	SSH, HTTP
ADMIN	admin.team15.isucdc.com	159.75.35.40	80, 3389	HTTP, RDP
WWW	www.team15.isucdc.com	159.75.35.50	80, 22	HTTP, SSH

Active Directory

ad.team15.isucdc.com

The AD server is running Windows Server 2016.

As a domain controller, we have joined all the other servers to manage access and authenticate users. We decided to conduct an audit of this server as its security is critical to maintaining control of the network and found various security risks that we corrected.

Identifying Vulnerabilities:

Before beginning formal hardening work, we restored the disabled Windows Update service and brought the system up to date. In this time, we also verified that there did not appear to be any existing malicious users. Once updates were completed, we ran a Windows Defender full scan and created our permission groups. We also verified that the firewall rules appeared to be sufficient.

Permission Structure:

We use our Active Directory server as both an authentication and authorization provider (via LDAP and group membership). For each centralized permission on each computer, we created a group for the permission, then added the relevant job role group to this permission group in the *Permission Roles* OU. On the other machines on the network, we used the relevant group to gate the given permission.

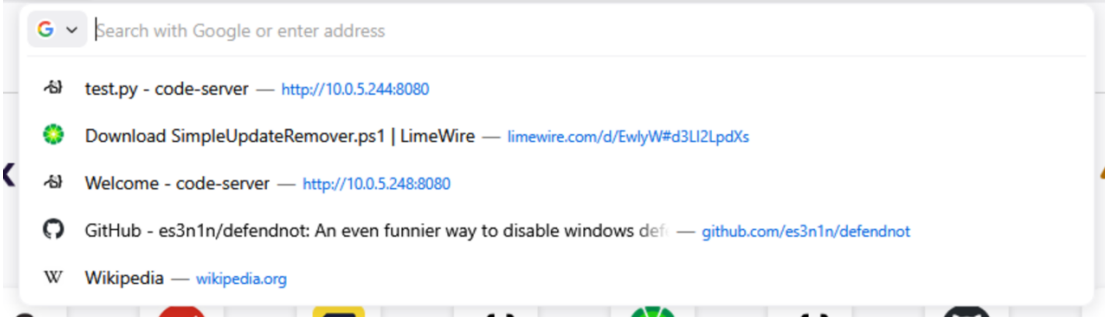
Ticketing Machine

tickets.team15.isucdc.com

The ticket server is running Windows Server 2019.

Identifying Vulnerabilities:

Our initial survey of the machine included looking through the search history on Firefox, and attempting to run windows antivirus. This check revealed some possible malware sources, as well as revealing that windows defender antivirus has been removed.



We also discovered that windows updates have been suppressed, meaning the windows update components would need to be reset. We also found suspicous and unnecessary users that needed to be disabled.

Fixes:

We first reinstalled windows defender antivirus using the command:

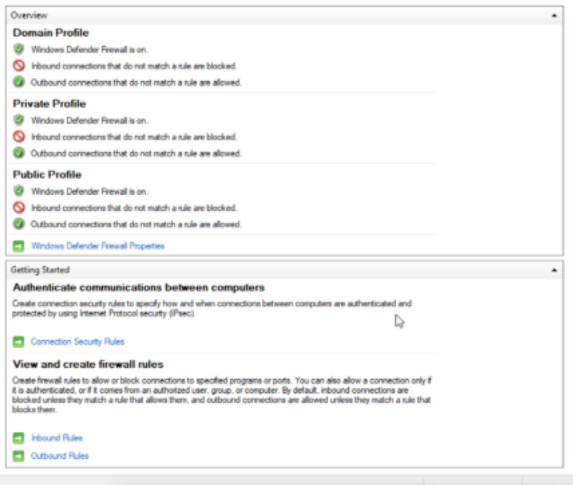
```
Install-WindowsFeature -Name Windows-Defender
```

We ran a quick scan that revealed a Trojan malware named sus.exe. This executable was removed.

We used lusrmgr to remove the following backdoor users:

- cdc
- scrat
- guest
- DefaultAccount
- Backdoor
- WDAGUtilityAccount

The firewall was reenabled, and added rules to allow HTTP in on port 5000, as well as RDP in on 3389.



Fixed bug allowing for large expiration time in the TicketsController.cs file

Downloaded all Windows Updates

Management Backend {}{}{}

mgmt.team15.isucdc.com

The management backend server is running Alma Linux 8.4.

Identifying Vulnerabilities:

To identify and patch vulnerabilities in the management server, we took several actions. The first was running system-wide updates on all software contained within the server. This was completed using DNF, Alma Linux's core package manager. Our second step was establishing and configuring a functional firewall which allows for minimal external interaction with the system. This was completed using Linux's Uncomplicated Firewall Application (UFW). Thirdly, we audited users on the system and restricted SSH access to prevent connected based on SSH keys, instead requiring password authentication.

Finally, we rotated the admin and root password to ensure that these valuable user accounts are not compromised.

Fixes

To update the system, we used the following commands:

sudo dnf update –nogpgcheck

sudo dnf check-update

To configure the UFW firewall, we applied the following policies:

Default deny all incoming and outgoing traffic.

Allow out HTTP, HTTPS, DNS

Allow in SSH, HTTP (port 5000)

To restrict users and reconfigure SSH we edited the SSH config file sshd_config and audited /etc/ssh/ssh_config.

To change user passwords, we used Linux's passwd command.

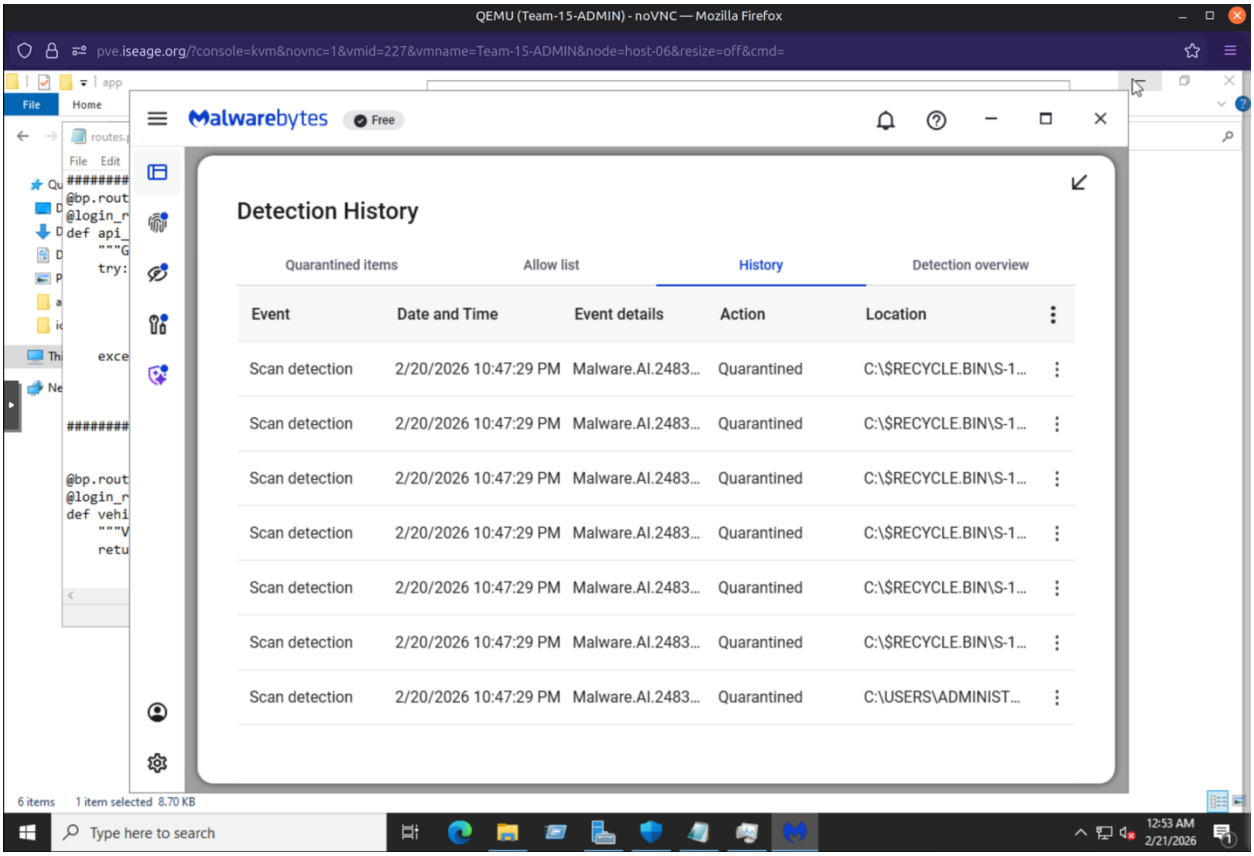
Admin User Interface

admin.team15.isucdc.com

This admin UI server is running Windows Server 2022.

Identifying Vulnerabilities:

Our first goal on this device was to update the windows operating system and complete a full scan on defender and as well as Malwarebytes. Next we secured the allowed users and locked down group rights and permissions. A restrictive firewall was also enabled on the device. There was also issue with the admin service it's self with users being able to log in and change the status of the buses and trains without admin permissions being checked for.



Public Website {}{}{}

www.team15.isucdc.com

The public website is running on Alma Linux 9.

Identfying Vulnerabilities:

Noticed a PLATYPUS file in every directory. Checked for rootkits in the LD_PRELOAD environment variable and found one. The variable was removed from the startup profile and the malicious library was quarantined.

Fixes:

There was a weak secret key of "cdc" on the Flask server, which enables an attacker to forge a valid session in another user's name by replacing their session cookie. This vulnerability was remediated by introducing a secure secret key.”System updates